PASTA worksheet: sneaker company app

Scenario	A sneaker company is building an app where customers can sign up, search the catalog and pay. I used PASTA (Process for Attack Simulation and Threat Analysis) to look at the app from the business goals down to the controls, one stage at a time.

I. Define business and security objectives	Customers can create a profile in the app or sign in with an account from another service. The app takes payments, so it handles card data and has to follow PCI DSS. Search and listings are used all the time, so the back end has to stay fast, available and correct.
II. Define the technical scope	Technologies used by the application: application programming interface (API), public key infrastructure (PKI), SHA-256, SQL. I would put the API first. Almost everything goes through it: login, search, payments and the link with outside services. That means it touches a lot of sensitive data and has the largest attack surface. The database comes second, because that is where the data ends up, but a weak API opens the way to it.
III. Decompose application	Product search process, the one flow I mapped: 1. The customer types a search in the app. 2. The app sends the request to the API. 3. The API queries the product database. 4. The database returns the current listings. 5. The API sends the results back to the customer. A real data flow diagram for an app like this is much bigger. This is a single process.
IV. Threat analysis	External: SQL injection through the search box or another input, to read or change data. Internal: an employee or contractor with more access than the job needs, who copies or changes customer data on purpose or by mistake.
V. Vulnerability analysis	Database queries that are built by pasting user input into the SQL text, instead of using prepared statements. API tokens that never expire and are not tied to a single session, so a stolen token keeps working for as long as the attacker likes.
VI. Attack modeling	Goal: steal user data. Branch 1: SQL injection, possible because the queries do not use prepared statements. Branch 2: account takeover with a stolen session token or a weak password, possible because tokens do not expire and passwords are not checked for strength.
VII. Risk analysis and impact	1. Prepared statements and input validation, to close the injection path. 2. Principle of least privilege, so an account only reaches the data it needs.

	3. A password policy with multifactor authentication, and tokens that expire. 4. Logging and an incident response procedure, so an attack is noticed and handled quickly.

What I took from it

PASTA starts from what the business needs and not from the technology, and I liked that. Once the objectives were clear it was easy to see why the API deserved the most attention, and the two vulnerabilities I picked lined up with the two branches of the attack tree. Each control at the end answers one of them.